

Security+ 4.1 · Application Security

Mestre CyberSec — PDF baseado na aula do Professor Messer · 4.1 — Application Security (8:26) · [vídeo original ↗](#) · [YouTube ↗](#)

AppSec: input validation (NUNCA confie no input — sanitize tudo); secure cookie (HttpOnly, Secure, SameSite); code signing (assinatura do executável); sandboxing; SAST (static code analysis).

💡 Highlights que a prova cobra

- Input validation: base de TUDO — sanitize/escape/whitelist
- HttpOnly cookie: JS não lê — mitiga stealing (XSS)

🎯 Dicas de prova

- 'JavaScript cannot access=this cookie'=HttpOnly

Cenário clássico: 'aplicação sanitiza input do usuário antes de processar'= input validation.

✅ Perguntas de treino (10 questões)

Gabarito no fim. Tenta responder SEM olhar.

1. Injeção de comando SQL num campo de login explora principalmente a falta de:

- A) Criptografia do disco
- B) Validação de entrada (input)
- C) Backup
- D) Antivírus

2. Injetar script malicioso numa página pra rodar no navegador de OUTROS usuários:

- A)** XSS (Cross-Site Scripting)
- B)** CSRF
- C)** SQLi
- D)** Buffer overflow

3. Cenário corporativo (Application Security): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 4.1), um analista avalia o seguinte requisito técnico: 'Input validation: base de TUDO — sanitize/escape/whitelist'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Implementar a solução correspondente: Input validation: base de TUDO — sanitize/escape/whitelist...
- B)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

4. Cenário corporativo (Application Security): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 4.1), um analista avalia o seguinte requisito técnico: 'HttpOnly cookie: JS não lê — mitiga stealing (XSS)'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Implementar a solução correspondente: HttpOnly cookie: JS não lê — mitiga stealing (XSS)...
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

5. Cenário corporativo (Application Security): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 4.1), um analista avalia o seguinte requisito técnico: 'JavaScript cannot access=this cookie'=HttpOnly'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Implementar a solução correspondente: 'JavaScript cannot access=this cookie'=HttpOnly...
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

6. Cenário corporativo (Application Security): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 4.1), um analista avalia o seguinte requisito técnico: 'aplicação sanitiza input do usuário antes de processar' = input validation.'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Implementar a solução correspondente: 'aplicação sanitiza input do usuário antes de processar' = input validation....
- B)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

7. Cenário corporativo (Application Security): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 4.1), um analista avalia o seguinte requisito técnico: 'Input validation: base de TUDO — sanitize/escape/whitelist'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Permitir acesso compartilhado entre administradores com credenciais genéricas
- D)** Implementar a solução correspondente: Input validation: base de TUDO — sanitize/escape/whitelist...

8. Cenário corporativo (Application Security): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 4.1), um analista avalia o seguinte requisito técnico: 'HttpOnly cookie: JS não lê — mitiga stealing (XSS)'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Implementar a solução correspondente: HttpOnly cookie: JS não lê — mitiga stealing (XSS)...
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

9. Cenário corporativo (Application Security): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 4.1), um analista avalia o seguinte requisito técnico: 'JavaScript cannot access=this cookie'=HttpOnly'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Implementar a solução correspondente: 'JavaScript cannot access=this cookie'=HttpOnly...
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

10. Cenário corporativo (Application Security): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 4.1), um analista avalia o seguinte requisito técnico: 'aplicação sanitiza input do usuário antes de processar'= input validation.'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Implementar a solução correspondente: 'aplicação sanitiza input do usuário antes de processar'= input validation....
- B)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

GABARITO COMENTADO

1) B — Validação de entrada (input). SQL injection acontece quando a aplicação NÃO valida/sanitiza o que o usuário digita e joga direto no banco. Validação de entrada é a defesa.

2) A — XSS (Cross-Site Scripting). XSS injeta JavaScript que roda no navegador da vítima. Defesa: sanitizar/escapar a saída. SQLi ataca o banco; CSRF força ação autenticada.

3) A — Implementar a solução correspondente: Input validation: base de TUDO — sanitize/. Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 4.1 (Application Security): Input validation: base de TUDO — sanitize/escape/whitelist. As demais alternativas configuram violações graves d

4) C — Implementar a solução correspondente: HttpOnly cookie: JS não lê — mitiga steali. Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 4.1 (Application Security): HttpOnly cookie: JS não lê — mitiga stealing (XSS). As demais alternativas configuram violações graves de confor

5) C — Implementar a solução correspondente: 'JavaScript cannot access=this cookie'=Http. Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 4.1 (Application Security): 'JavaScript cannot access=this cookie'=HttpOnly. As demais alternativas configuram violações graves de conformid

6) A — Implementar a solução correspondente: 'aplicação sanitiza input do usuário antes. Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 4.1 (Application Security): 'aplicação sanitiza input do usuário antes de processar'= input validation.. As demais alternativas configuram v

7) D — Implementar a solução correspondente: Input validation: base de TUDO — sanitize/. Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 4.1 (Application Security): Input validation: base de TUDO — sanitize/escape/whitelist. As demais alternativas configuram violações graves d

8) B — Implementar a solução correspondente: HttpOnly cookie: JS não lê — mitiga steali. Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 4.1 (Application Security): HttpOnly cookie: JS não lê — mitiga stealing (XSS). As demais alternativas configuram violações graves de confor

9) B — Implementar a solução correspondente: 'JavaScript cannot access=this cookie'=Http. Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 4.1 (Application Security): 'JavaScript cannot access=this cookie'=HttpOnly. As demais alternativas configuram violações graves de conformid

10) A — Implementar a solução correspondente: 'aplicação sanitiza input do usuário antes. Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 4.1 (Application Security): 'aplicação sanitiza input do usuário antes de processar'= input validation.. As demais alternativas configuram v

